**INTERNATIONAL CYBERSECURITY AND DIGITAL FORENSICS ACADEMY (ICDFA)**

| **Submission detail** | **Entry** |
|---|---|
| **Student name** | **Kelechi Kenneth Nwankwo** |
| **Student ID** | **2025/GCR/12814** |
| **Official email** | **gcr2512814@students.icdfa.edu.ng** |
| **Role adopted** | **Incident Response Lead, Northbridge Skills Institute (fictional)** |
| **File name** | **GRC105_Incident Response Planning _2025/GCR/12814** |
| **Submission date** | **19th October, 2026** |

# Introduction

This report sets out how I would lead the first 24 hours of the suspected ransomware incident at Northbridge Skills Institute, and how I would prepare the institute to handle the next one better. I took control at 08:45 WAT on Day 0 (Monday), with 100 learners due to sit an online examination at 11:00. Every decision below is tied to the evidence pack (E01 to E08) so that a reader can see why I chose it, and where I am working from a hypothesis rather than a fact.

How the work is organised. I used the four teaching stages (ICDFA, n.d.) as the spine of the report. Where I refer to NIST SP 800-61 Revision 3, I use its CSF 2.0 alignment: Detect, Respond and Recover together form incident response, while Govern, Identify and Protect support preparation (NIST, 2025). I have not attributed the four-stage model to Revision 3. The wider incident response life cycle overview on the NIST project page was used to check that every stage is covered (NIST, n.d.).

| Teaching stage | Where it is addressed | NIST SP 800-61r3 / CSF 2.0 link |
|---|---|---|
| **1. Preparation** | Task 2 (policy, CSIRT, RACI, readiness); Task 5 improvement plan | Govern, Identify, Protect |
| **2. Detection and analysis** | Task 1 (timeline, classification, investigation questions) | Detect (with Identify) |
| **3. Containment, eradication and recovery** | Task 3 (playbook, evidence, restoration); Task 4 (communication) | Respond, Recover |
| **4. Post-incident activity** | Task 5 (tabletop, improvements, review); Task 6 (reflection) | Improvement feeding all functions |

**Working conventions**

- All times are West Africa Time (WAT). Day 0 is Monday; Day minus 1 is Sunday; Day minus 3 is the preceding Friday.
- Evidence IDs E01 to E08 come from the supplied pack. Evidence I propose to collect is given new IDs (EV-01 onwards) and is always described as **planned, not yet collected**. I have not invented hashes, and I do not claim any acquisition has taken place.
- Assumptions are labelled A1 to A8 below. Names and telephone numbers are fictional.

| ID | Assumption | Why it matters |
|---|---|---|

| | | |
|---|---|---|
| **A1** | Northbridge is assumed to operate in Nigeria and to be a data controller under the Nigeria Data Protection Act 2023 (NDPA). | Sets the legal notification framework in Task 4. A different jurisdiction would change the deadline. |
| **A2** | FS01 and LMS01 run as virtual machines that can be snapshotted; if they are physical, the same steps apply using disk imaging. | Affects how fast volatile evidence can be preserved. |
| **A3** | The 100 examination candidates are the only hard external deadline today; no payroll or funding deadline falls in the first 24 hours. | Shapes restoration order. |
| **A4** | The Friday 17:00 disconnected backup is held on physically separate media that has not been connected since it was written. | Makes it the only candidate I can reasonably trust (see Task 3). |
| **A5** | The institute has no standing forensic retainer or cyber-insurance contact today, so both must be arranged on the day. | Drives the escalation and support steps. |
| **A6** | The Principal acts as executive sponsor; the Head of Academic Operations owns the examination and learner services. | Defines who approves what. |
| **A7** | Staff mobile numbers are available through personal phones (E08 states phones are available). | Basis for the out-of-band call tree. |
| **A8** | The finance officer is reachable by phone and willing to be interviewed. | Needed to resolve E01 and E02. |

# Task 1: Incident classification and initial assessment

Stage: detection and analysis. My aim in the first minutes is to decide what is known, what is merely likely and what is still open, because over-claiming in either direction would send the response the wrong way.

| ID | Time (WAT) | Confirmed observation | Working hypothesis (not proven) | Unresolved question |
|---|---|---|---|---|
| E01 | Day -1 (Sun) 16:40 | A finance officer opened an unexpected payroll attachment on FIN-PC07 (user report and mail record). Execution of malicious code is **not** verified. | The attachment was a phishing payload and is the likely initial access route. | Did it run? What type of file was it? Did other staff receive the same email? |
| E02 | Day 0 01:15 | The finance officer account signed in from an unfamiliar IP and a new device (Microsoft 365 audit). | The credentials or session token were stolen after E01 and replayed by an attacker. | Was MFA satisfied, and how? Was the officer involved (new phone, travel, VPN)? |
| E03 | Day 0 01:35 | svc_backup made remote administrator logons to FS01 and BAK01 outside its normal schedule. | The attacker used svc_backup (or its credentials) to move | What started the logons, and from which source host? Was there an |

| | | | | |
|---|---|---|---|---|
| | | | laterally and reach the backups. | approved change window? |
| E04 | Day 0 01:50 | FIN-PC07 uploaded 1.2 GB over HTTPS to unfamiliar cloud storage. Content is unknown. | Finance data was staged and exfiltrated to support extortion. | What was in the upload? Who owns the destination? Was any of it personal data? |
| E05 | Day 0 02:00 | The backup console reports success for FS01 and LMS01 jobs. | Jobs ran, but the restore points may hold already-compromised data, or the console may be unreliable. | Are the restore points readable, unaltered and free of malware? Were jobs or retention changed? |
| E06 | Day 0 08:30 | EDR and helpdesk show mass file changes on FIN-PC07; FS01 shared folders hold .locked files and a ransom note. Family unconfirmed. | Ransomware was executed on the workstation and the file server, probably via the same intruder access seen in E02 and E03. | Which family? Is encryption still spreading? When did it start, and which other hosts are touched? |
| E07 | Day 0 08:40 | The portal login page loads, but learners cannot open materials or submit assessments. | The portal depends on files held on FS01, which are now encrypted. LMS01 itself may be intact. | Is LMS01 (application or database) compromised, or only starved of its files? |
| E08 | Day 0 08:45 | The incident contact list on FS01 is inaccessible; staff phones work. Corporate email trust is unverified. | Because E02 involved a mailbox, email may be monitored by the attacker. | Are there forwarding rules, rogue app consents or other mailboxes affected? |

**Observation on the timeline.** Roughly six and a half hours separate the last overnight indicator (E05, 02:00) from the first visible damage (E06, 08:30). Nothing in the pack shows that anyone saw E02 to E04 as they happened. That is a detection gap, and I treat it as a finding for the post-incident review rather than a question for today.

## 1.2 Alternative explanations for ambiguous events

| Event | Malicious explanation | Plausible alternative | Check that separates them |
|---|---|---|---|
| **E02** | Attacker replayed a stolen token or password from their own infrastructure. | The officer signed in on a new phone or from a mobile network or VPN, perhaps while working on a Sunday night on payroll. | Sign-in log detail: user agent, IP reputation and location, MFA method and result; call the officer. |
| **E03** | Attacker used harvested svc_backup credentials to reach FS01 and BAK01. | IT ran an out-of-hours maintenance job, a patch window or a backup rescan that was not recorded. | Check change tickets; identify source host and session process on FS01 and BAK01; ask the three IT staff. |
| **E04** | Data theft staged from the finance workstation for double extortion. | An authorised or personal cloud sync (for example a user backing up files) or a software update using cloud storage. | Proxy URL and SNI detail, destination ownership, file list and archive staging on FIN-PC07. |
| **E05** | Backups were reported successful while already holding encrypted, tampered or infected data. | The jobs are genuinely healthy and the restore points are clean, because they ran before encryption began. | Test restore into an isolated sandbox; compare catalog hashes; review job and retention change logs. |

| | | | |
|---|---|---|---|
| **E07** | LMS01 is itself compromised or damaged. | The application is healthy but cannot read its content because the files on FS01 are encrypted. | Integrity and AV scan of LMS01; inspect application logs and the database; test with a copy of content. |

## 1.3 Classification and severity

**Incident type.** Ransomware infection with suspected data theft (a "double extortion" pattern), following a probable phishing-led account compromise and the use of a privileged service account. I record it as a confirmed ransomware event (E06) with suspected, unconfirmed exfiltration (E04) and a suspected threat to backups (E03, E05).

**Severity criteria used by the institute.**

| Level | Criteria (any one of the first two, aggravated by uncertainty) | Required response |
|---|---|---|
| **Critical** | Production servers or core services unavailable or encrypted, or a hard business deadline at risk; sensitive personal or finance data possibly exposed at scale; backups or recovery path in doubt; attacker may still be active. | Full CSIRT activated at once; Principal told within 15 minutes; external support engaged; hourly updates. |
| **High** | One important service or department significantly disrupted; malware execution confirmed on a limited set of systems; possible but limited personal data exposure; recovery path known and tested. | CSIRT core team within 30 minutes; management told within 1 hour; updates every 2 hours. |
| **Medium** | Single endpoint malware or suspicious account activity with no evidence of spread, data access or service impact. | Security analyst and IT operations respond; IR Lead informed; daily update. |
| **Low** | Blocked attempts, policy breaches or isolated events with no impact on services or data. | Handled in routine operations and logged. |

**Selected level: Critical.** My reasons, in the three dimensions the brief asks for:

- **Operational impact.** The file server holding shared folders is encrypted (E06), the portal cannot serve materials or accept submissions (E07), the contact list is lost (E08), and 100 learners are due to be examined in 2 hours 15 minutes.
- **Affected data.** FS01 and FIN-PC07 hold admissions documents, assessment records and finance files. A 1.2 GB upload (E04) means theft cannot be ruled out, although nothing yet proves it.
- **Uncertainty.** The privileged service account was used out of pattern on the backup repository (E03), and the "successful" backups are unvalidated (E05). With the recovery path in doubt and attacker presence unconfirmed, the cost of under-classifying is far larger than the cost of over-classifying.

**Rule for revisiting the level.** I classify upward on suspicion and downgrade only on evidence. I would consider moving to High only if (a) E02 and E03 are shown to be benign, (b) the Friday backup restores cleanly, and (c) no sign of exfiltration or wider spread is found. Nothing short of that justifies lowering the response.

## 1.4 Affected assets and CIA assessment

| Asset | Status | Basis |
|---|---|---|
| **FIN-PC07 (finance workstation)** | Confirmed affected | Mass file changes (E06); malicious attachment opened (E01); large upload (E04). |
| **FS01 (file server)** | Confirmed affected | .locked files and ransom note on shared folders (E06); out-of-pattern admin logon (E03). |
| **LMS01 (learning portal)** | Potentially affected | Functional failure (E07) is explained by FS01 dependency, but compromise is not excluded. |
| **BAK01 (backup repository)** | Potentially affected | svc_backup admin logon (E03); backups not immutable; restores untested (E05). |
| **svc_backup account** | Potentially compromised | Unusual logons (E03); admin rights over FS01 and BAK01. |
| **Finance officer M365 account and mailbox** | Potentially compromised | Unfamiliar IP and new device (E02); email trust unverified (E08). |
| **Learner, admissions, assessment and finance data** | Potentially exposed | Held on FS01 and FIN-PC07; possible exfiltration (E04) not proven. |
| **Last disconnected backup (Friday 17:00)** | Not indicated as affected | Disconnected, so unreachable from the attacker's network path on Day -1 to Day 0 (A4). Still requires validation before use. |

| Property | Assessment | Confidence |
|---|---|---|
| **Confidentiality** | Unknown but plausible loss. Evidence is indirect (E02, E04); there is no direct proof of data theft and none that data was not stolen. Treated as at risk until logs say otherwise. | Low to moderate |
| **Integrity** | Confirmed loss on FIN-PC07 and FS01 (encrypted files, E06). Integrity of backup contents and of LMS01 data is unknown (E05, E07). | High for FS01 and FIN-PC07; low elsewhere |
| **Availability** | Confirmed degradation: shared files, portal content and submissions, and the contact list are unavailable (E06 to E08). The examination is directly threatened. | High |

## 1.5 Response priorities

| Rank | Priority | Reason and evidence |
|---|---|---|
| 1 | Stop spread and protect what is still clean, above all BAK01 and the disconnected Friday backup. | E03 and E05 point to a possible attack on recovery; E06 shows encryption already under way. |
| 2 | Secure identities: disable svc_backup, revoke the finance officer's sessions, block the unfamiliar IP. | E02 and E03 suggest the attacker holds valid credentials; without this, containment can be undone. |
| 3 | Preserve volatile evidence while containing (isolate, do not power off). | E06: memory on FIN-PC07 and FS01 holds the best evidence of what ran. It is lost on shutdown. |
| 4 | Set up a trusted coordination channel and a call tree outside FS01 and email. | E08: contact list inaccessible; email trust unverified. |
| 5 | Decide the 11:00 examination at a defined gate (10:15) using explicit safety criteria. | The deadline is real, but reopening on unverified data risks integrity and reinfection (E05, E07). |
| 6 | Establish whether personal data left the network. | E04 starts a possible legal clock (Task 4) and determines learner communication. |
| 7 | Plan recovery from a validated backup in a controlled environment. | E05: success messages are not proof of recoverability. |

## 1.6 Priority investigation questions

| Question | Check that could resolve it | Why it matters | Finding that would change my assessment |
|---|---|---|---|
| **Q1. Did the E01 attachment run, and is it the entry point?** | EDR process tree and file-write timeline on FIN-PC07; mail trace and header of the original message; sandbox detonation of a copy; interview the officer (A8). | Fixes the entry vector and shows whether other users received it. | Same email in other mailboxes, or a different entry route (for example an exposed remote-access service), would **widen scope** to all recipients or the perimeter. |
| **Q2. Was data exfiltrated, and what was in the 1.2 GB (E04)?** | Full proxy URL/SNI and destination details; DNS and firewall flow records; file list and staging archives on FIN-PC07; file-access audit on FS01; any attacker "proof" later supplied. | Determines confidentiality impact, learner notification and the legal clock. | Learner or staff personal data confirmed in the upload **keeps Critical and triggers formal legal assessment**. A benign sync would reduce the data-theft concern but not the encryption impact. |
| **Q3. Is svc_backup compromised, and are the backups safe (E03, E05)?** | Windows Security logs on FS01 and BAK01 (logon type, source host, process creation); backup job, retention and credential change history; test restore into a sandbox; scan restored data. | Decides whether recovery is possible at all and which backup I can trust. | Evidence of backup tampering or deletion **increases scope** to the entire backup estate and leaves only the offline copy. A clean restore with a documented maintenance reason would ease it. |

| | | | |
|---|---|---|---|
| **Q4. Is the attacker still active in Microsoft 365 or on other servers?** | Unified audit log; sign-in logs; mailbox rules, forwarding and OAuth consents; privileged role changes; EDR hunts for the same indicators on every endpoint, and manual triage on servers without EDR. | Containment fails if access remains; also tests E08. | New admin accounts, rogue app consents or the same indicators on other hosts **extend scope to tenant-wide credential reset** and wider rebuilds. |
| **Q5. Is LMS01 damaged or only dependent on FS01 (E07)?** | Offline integrity check and AV scan of LMS01; review application and database logs; check whether files LMS01 needs are encrypted. | Determines how fast the exam environment can be restored. | Database corruption or malware on LMS01 moves it to **confirmed affected** and removes the quick-fix route for the examination. |

# Task 2: Incident response plan and team responsibilities

Stage: preparation. This is the plan I would want to have been holding at 08:45. Parts of it did not exist on the day, which is why Task 5 turns the gaps into an improvement plan. It is deliberately short enough for a three-person IT team to use under pressure.

| Element | Statement |
|---|---|
| **Mission** | To protect learners, staff and the integrity of assessment by detecting, containing and recovering from security incidents quickly and safely, while meeting legal duties and learning from every event. |
| **Objectives** | (1) Limit harm and stop spread. (2) Preserve evidence so we can establish what happened. (3) Restore services in business-priority order from validated sources. (4) Communicate accurately and on time. (5) Meet legal and contractual obligations. (6) Improve after every incident and exercise. |
| **Scope** | All Northbridge systems, data and people: FIN-PC07 and all endpoints, FS01, LMS01, BAK01, Microsoft 365 identity and email, third-party services holding institute data, and any personal devices used to access them. Applies to staff, contractors and service providers. |
| **Incident declaration** | Anyone may report a suspected incident to the Security Analyst or IT Operations Lead. An incident is **declared** by the IR Lead when any of these is met: malicious code is confirmed or credibly suspected on a production system; privileged or cloud credentials are suspected compromised; a critical service is unavailable through suspected malicious action; or personal data may have been accessed, lost or disclosed. The declaration time is recorded as the start of the incident log. |
| **Activation and escalation** | Severity follows the Task 1 scale. **Critical:** full CSIRT, Principal informed within 15 minutes, external forensic and legal support engaged within 2 hours, hourly updates. **High:** core CSIRT in 30 minutes, management within 1 hour. **Medium/Low:** handled by IT and security, logged, reviewed daily. Escalation is automatic if scope grows, a deadline (such as an examination) is threatened, |

| | |
|---|---|
| | an extortion demand or media enquiry arrives, or the IR Lead is unreachable for 15 minutes, in which case the IT Operations Lead acts as deputy. |
| **Authority to isolate** | The IR Lead, or the deputy, is pre-authorised to isolate any system, disable any account, block any network destination and suspend any backup job during a declared Critical or High incident, **without waiting for management approval**. The Business Owner and Principal are informed immediately afterwards. Reconnecting an isolated system requires the IR Lead and the Business Owner together. |
| **Documentation** | A scribe keeps a time-stamped incident log (WAT) from declaration. Four records are mandatory: incident log, decision log (decision, owner, rationale, effect), evidence register with chain of custody, and a communications log. Records are held outside FS01 and corporate email until the environment is declared clean. |
| **Plan review** | Reviewed at least annually; after every Critical or High incident (action review within 14 days); after each tabletop exercise (twice a year); and whenever systems, suppliers or legislation change. The IR Lead owns the plan and the Principal approves changes. |

**Link to business continuity.** The plan and the business continuity plan operate as one decision chain. Declaring a Critical incident automatically invokes continuity: the Head of Academic Operations (Business Owner) takes over service-priority decisions and uses the business impact analysis to set recovery order, RTO and RPO. Security answers "is it safe to restore?" and the Business Owner answers "is it ready for the business?". Neither can override the other: restoration needs both. Continuity options for examinations (rescheduling, offline or paper-based assessment, alternative venues) are prepared by the Business Owner in parallel with technical recovery, so that learners are not left waiting for IT. In NIST terms, this plan sits mainly in Govern and Identify (policy, roles, impact analysis) and Protect (readiness), and feeds Detect, Respond and Recover (NIST, 2025).

## 2.2 CSIRT structure

Northbridge has three IT staff and one security analyst, so the CSIRT is mostly existing people wearing incident hats, with pre-agreed outside help for what they cannot cover.

| Role | Held by | Core responsibilities in an incident | Deputy |
|---|---|---|---|
| **1. Incident Manager (IR Lead)** | Senior IT/security lead (me) | Declares the incident, sets severity, directs actions, owns the decision log, controls the isolation authority, briefs the Principal. | IT Operations Lead |
| **2. Security Analyst** | Security analyst | Triage, log and EDR analysis, threat hunting, indicator tracking, credential and cloud-account containment. | External DFIR analyst |

| | | | |
|---|---|---|---|
| **3. Digital Forensics Lead** | External DFIR retainer; interim in-house evidence custodian | Evidence collection, integrity checks, chain of custody, forensic analysis and reporting. | Security Analyst (collection only) |
| **4. IT Operations Lead** | IT team lead | Isolation actions, rebuilds, restores, backup operations, change control, system hardening. | IT technician |
| **5. Business Owner** | Head of Academic Operations | Business impact decisions, examination and learner-service continuity, restoration approval, acceptance of residual risk. | Registrar |
| **6. Legal and Privacy Adviser** | Data protection officer with external counsel | Assesses reporting duties, advises on regulator, law-enforcement and contract notifications, privilege over investigation material. | External counsel |
| **7. Communications Lead** | Marketing and communications manager | Drafts and issues stakeholder messages, manages media and social channels, keeps the communications log. | Student services manager |
| **8. Executive Sponsor** | Principal | Approves spend, external engagement, public statements and formal notifications; resolves conflicts between security and business. | Deputy Principal |
| **9. Scribe and Evidence Custodian** | Administrator trained for the role | Keeps the incident log and decision log; holds the evidence register and custody forms. | Any trained administrator |

**Getting extra help.** The small team cannot sustain a Critical incident alone, so support is requested early, not when we are exhausted. Triggers: any Critical declaration, scope beyond one analyst, or any suspected data theft. Sources, arranged in advance: (1) an external digital forensics and incident response (DFIR) retainer; (2) external legal counsel with data protection experience; (3) the Microsoft 365 partner and backup vendor support lines, with named contacts; (4) the national CERT and, through counsel, law enforcement; (5) a mutual-aid arrangement with a peer institution for temporary IT staff and shared exam venues; (6) the cyber-insurer hotline, if cover exists (A5). Rest rotations are set at the first update: no individual works more than 12 hours without relief, because fatigue causes mistakes in containment and evidence handling.

## 2.3 RACI matrix

**Key.** R = Responsible (does the work). A = Accountable (one person who answers for the result and can say yes or no). C = Consulted (gives input before decisions). I = Informed (told afterwards). A/R means one role is both. Each activity has exactly one A. Roles: PR = Principal; IRL = IR Lead; SA = Security Analyst; FL = Forensics Lead; ITO = IT Operations Lead; BO = Business Owner; LP = Legal and Privacy Adviser; CL = Communications Lead.

| **Activity** | PR | IRL | SA | FL | OTO | BO | LP | CL |
|---|---|---|---|---|---|---|---|---|

| | | | | | | | | |
|---|---|---|---|---|---|---|---|---|
| **1. Detection and triage** | I | I | A/R | C | R | I | - | - |
| **2. Analysis and severity classification** | I | A | R | R | C | I | C | - |
| **3. Containment and isolation** | I | A | R | C | R | C | I | I |
| **4. Evidence handling and chain of custody** | - | I | R | A/R | R | - | C | - |
| **5. Stakeholder communication** | A | C | I | - | I | C | C | R |
| **6. Assessment of reporting obligations** | C | C | I | C | - | I | A/R | I |
| **7. Eradication and hardening** | I | A | R | C | R | I | - | - |
| **8. Restoration execution and validation** | I | C | R | C | A/R | C | - | I |
| **9. Restoration approval (service return)** | I | R | C | C | C | A/R | C | I |
| **10. Closure and post-incident review** | C | A/R | R | R | R | C | C | C |

**Reading the matrix.** The Principal is accountable for what the institute says publicly (activity 5) but does not write it; the Communications Lead does. The decision that a notification is legally required is made by the Legal and Privacy Adviser, with the Principal consulted before anything is filed. For restoration, the Business Owner is accountable for approving service return and the IR Lead is responsible for certifying that the security criteria are met, which keeps "safe" and "ready" as two separate signatures.

## 2.4 Preparation improvements and readiness checklist

| # | Improvement | Owner | Resources needed | How readiness is checked | Target |
|---|---|---|---|---|---|
| 1 | **Backup readiness:** immutable or offline copies for FS01, LMS01 and BAK01 data; separate backup credentials with MFA; regular restore testing. | IT Operations Lead | Immutable (write-once) storage tier or object lock; rotating offline media; test environment; about 2 days of staff time each quarter. | Quarterly restore of FS01 and LMS01 into an isolated sandbox; pass means integrity check complete, restore time recorded against RTO, and report signed. First test within 30 days. | First test 30 days; immutability 60 days |
| 2 | **Accessible incident contact list:** printed cards and encrypted phone copies, plus a copy hosted outside FS01 and email. | IR Lead | Printed A5 cards; secure messaging group for the CSIRT; sealed copy in the reception safe; monthly update. | Quarterly unannounced call-tree drill: all nine roles reached in 15 minutes or less; list accuracy audit monthly. | 7 days |
| 3 | **Tools:** EDR and logging coverage on all servers; log retention held off-box. | Security Analyst | EDR licences for FS01, LMS01, BAK01; central log store with at least 90 days of retention; M365 audit retention enabled. | Weekly coverage report showing 100% of servers reporting; monthly safe test alert reaching the analyst within 5 minutes. | 30 days |
| 4 | **Privileged access:** remove standing admin rights from svc_backup, deny interactive logon, vault the credential, require phishing-resistant MFA for admins. | IT Operations Lead | Admin account redesign; password vault; conditional access policy; 3 to 5 days of effort. | Quarterly privileged-account review; alert on out-of-hours use of any admin or service account tested and firing. | 21 days |
| 5 | **Secure communication:** a pre-agreed out-of-band channel, templates and a status page hosted away from institute servers. | Communications Lead | Secure messaging app policy; externally hosted static page; SMS broadcast option; approved holding statements. | Used in every drill; template library reviewed twice a year; holding statement issued within 10 minutes in the next exercise. | 14 days |
| 6 | **Training and exercises:** phishing awareness, role-based incident training, two tabletop exercises a year. | IR Lead with HR | Phishing simulation tool; 1 hour of training per staff member; exercise facilitation time. | 90% or more of staff complete training; phishing-report rate tracked monthly; exercise actions closed on time. | 60 days; exercises every 6 months |
| 7 | **External support in place:** DFIR retainer, legal counsel, supplier escalation contacts and (if possible) insurer hotline. | Principal | Budget approval; signed retainers and NDAs; named contacts for M365 and backup vendors. | Retainer contracts on file; contact test call to each supplier twice a year. | 45 days |

# Task 3: Response playbook and evidence preservation

Stage: containment, eradication and recovery. The guiding principle is "isolate, do not switch off". Network isolation stops the damage while keeping memory, running processes and connections intact for investigators. Only when isolation cannot be achieved quickly do I accept evidence loss to stop harm (see 3.3).

## 3.1 Response playbook: first 60 minutes and first 24 hours

| Time or stage | Action | Owner | Approval | Evidence to retain | Completion check |
|---|---|---|---|---|---|
| **08:45 to 08:50** Declare | Declare a Critical incident. Open the incident log and decision log; assign the scribe; reach the CSIRT by phone using personal mobiles (E08). | IR Lead | Declared under plan authority; Principal informed | Copies of E01 to E08; call log; log start time | Incident log open; Principal and IT Ops Lead confirmed by voice |
| **08:50 to 09:00** Short-term containment | Isolate FIN-PC07 using EDR network containment (no power-off). Isolate FS01 from the network at the switch port or hypervisor virtual NIC, leaving it powered on. Cut BAK01 off the network and suspend all backup jobs. Stop LMS01 reaching FS01. | IT Ops Lead with Security Analyst | Pre-authorised (IR Lead) | EDR containment log; switch or firewall change record; photographs or screenshots; exact times | Hosts show isolated in EDR; file-share and ping tests from the user network fail; times logged |
| **08:50 to 09:05** Identity containment | Disable svc_backup (export its recent logon history first). Revoke all sessions and refresh tokens for the finance officer, force password reset and MFA re-registration, and review that user's sign-in history. Block the unfamiliar IP from E02. | Security Analyst and IT Ops Lead | IR Lead | Sign-in and audit log export taken **before** changes; screenshot of account state | Accounts disabled; no active sessions; sign-in log shows no activity after the cut time |
| **08:55 to 09:10** Block exfiltration | Block the destination from E04 at proxy, firewall and DNS. Restrict outbound uploads from the finance subnet. Search proxy logs for other hosts sending to the same destination. | Security Analyst | IR Lead | Proxy and firewall logs for E04; rule change record | Rule active; blocked attempts appear; no other host found sending to the destination, or hosts listed |
| **09:00 to 09:20** Preserve volatile evidence | Capture memory from FIN-PC07 (EDR live response or acquisition tool) and from FS01 if still running; snapshot FS01 and LMS01 virtual machines; copy | Forensics Lead (Security Analyst assists) | IR Lead | Memory images, snapshots, note and samples; hash values calculated at acquisition and recorded in the register | Each item entered in the evidence register as **collected** only after it is actually done |

| | | | | | |
|---|---|---|---|---|---|
| | the ransom note and sample encrypted files. | | | | |
| **09:00 to 09:20** Secure backups | Locate the Friday 17:00 disconnected backup, check seals and take custody; set BAK01 to read-only isolation; export backup job, retention and credential configuration; forbid any restore from BAK01 into production. | IT Ops Lead and Forensics Lead | IR Lead | BAK01 job and access logs; configuration export; custody form for the offline media | Offline media in locked custody with form signed; BAK01 isolated and no jobs running |
| **09:15 to 09:25** Command and communication | Move incident coordination to phones and a secure messaging group (no sensitive data in it). Issue the executive briefing (Task 4). Tell staff to avoid using corporate email for incident matters. | IR Lead and Communications Lead | Principal (for executive briefing) | Copies of briefing and messages; communications log | All CSIRT members reachable; briefing issued by 09:25 |
| **09:25 to 09:45** Scope check | Hunt for the indicators found so far (file names, hashes, processes, ransom note) on every endpoint with EDR. Manually triage LMS01 and BAK01, which lack EDR coverage. Search Microsoft 365 for other users who received the E01 email, and check for new forwarding rules, app consents and role changes. | Security Analyst (with external DFIR as available) | IR Lead | Hunt queries and results; indicator list; audit-log exports | Written list of hosts and accounts: affected, clear, or not yet checked |
| **09:45 to 10:15** Examination gate | Test whether a clean examination environment can be built from the validated Friday backup. Apply the go/no-go criteria in 3.3. Business Owner and IR Lead decide together; the Principal approves any postponement. | IR Lead and Business Owner | Principal | Gate checklist with results and times; decision record | Decision recorded and passed to the Communications Lead by 10:20 |
| **10:15 to 12:00** External support | Engage the DFIR provider and legal counsel; notify the insurer, M365 partner and backup vendor; begin forensic imaging of FIN-PC07 and FS01 disks; start the | IR Lead | Principal (spend) | Engagement records, ticket numbers, imaging records | Support teams confirmed working; counsel has been briefed |

| | | | | | |
|---|---|---|---|---|---|
| | data-exposure assessment. | | | | |
| **12:00 to 17:00** Investigation | Establish initial access (E01 to E02), lateral movement (E03), exfiltration (E04) and the ransomware family, using the ransom note and sample files; check whether a decryptor exists. | Security Analyst and Forensics Lead | IR Lead | Analysis notes, indicator lists, timeline updates | Hypotheses in 1.1 each marked confirmed, refuted or open |
| **12:00 to 17:00** Longer-term containment | Segment the network; reset credentials for all privileged and service accounts and for high-risk users; enforce MFA for all admin access; block indicators across proxy, DNS and EDR. | IT Ops Lead and Security Analyst | IR Lead | Change log with before and after configuration | Credential reset list signed off; sign-in logs show no old tokens in use |
| **17:00 to 22:00** Backup selection and validation | Check the catalog and hashes of the Friday backup; scan in an isolated sandbox; restore a test copy into a clean VLAN; compare file counts, sizes and sample content; confirm the backup pre-dates E01 (Sunday 16:40). | IT Ops Lead, Security Analyst, Forensics Lead | IR Lead and Business Owner review | Restore logs, scan reports, hash comparison, validation report | Written validation report signed by Security Analyst and IT Ops Lead |
| **Day 0 night to Day 1 06:00** Eradication | Rebuild FIN-PC07 from a clean image; rebuild or reimage FS01 and restore data into it; remove persistence (scheduled tasks, services, run keys, WMI, rogue accounts, mail rules, app consents); patch; close the entry route. | IT Ops Lead and Security Analyst | IR Lead | Persistence checklist, rebuild records, post-rebuild scan reports | Second person verifies each checklist item; indicator hunt returns zero matches |
| **Day 1 06:00 to 08:45** Controlled recovery | Return services in tiers (see 3.5): identity and communications, exam environment and LMS01, FS01 content, finance, remainder. Each tier is released only when it passes the acceptance criteria. | IT Ops Lead | Business Owner (each tier) | Change tickets, acceptance sign-offs, monitoring baseline | Tier signed off by Security Analyst, IR Lead and Business Owner |
| **From restoration** Monitoring | Raise logging and EDR sensitivity; place canary files on restored shares; named analyst reviews alerts daily; extend watch for 14 days. | Security Analyst | IR Lead | Alert records and daily review notes | No recurrence indicators for 24 hours before "stable"; 14 days before closure |

| | | | | | |
|---|---|---|---|---|---|
| **Day 1 08:45** 24-hour review and closure planning | Review status with the Principal; confirm notification decisions with counsel; set post-incident review and action owners (Task 5). | IR Lead | Principal | Review minutes; updated decision log | Closure criteria and review date agreed |

**Checking for broader compromise**

I assume that anything sharing credentials, network paths or trust with FIN-PC07, FS01 or svc_backup may be affected until shown otherwise. Checks: EDR indicator hunts on all workstations; manual triage on servers without EDR (LMS01, BAK01) because "no alert" means nothing where there is no sensor; review of privileged group membership and recently created accounts; review of Microsoft 365 sign-ins, forwarding rules, app consents and role assignments; proxy, DNS and firewall review for the E04 destination and other unusual uploads; and a mail search for the E01 sender and attachment across every mailbox. Results are recorded as affected, clear or unchecked, and "unchecked" is never reported as "clear".

## 3.2 Evidence register

Nothing below has been collected yet. Every entry is a **plan**, with the status "planned, not yet collected". Times are proposed for Day 0 (Monday) in WAT. Hash values will be calculated at the moment of acquisition and recorded then; I have not invented any here.

| ID | Source and item | Proposed collection method | Collector role | Planned date and time (WAT) |
|---|---|---|---|---|
| **EV-01** | FIN-PC07 volatile memory (E01, E04, E06) | EDR live response or memory acquisition tool run from external media; write to evidence drive. | Forensics Lead | Day 0, 09:00 to 09:15 WAT. Planned, not yet collected. |
| **EV-02** | FIN-PC07 disk image and EDR telemetry export | Forensic disk image using a write blocker after memory capture; export full EDR timeline. | Forensics Lead | Day 0, 10:30 to 14:00 WAT. Planned, not yet collected. |
| **EV-03** | FS01 virtual machine snapshot, memory (if running) and Windows Security and System logs (E03, E06) | Hypervisor snapshot including memory; export event logs; later forensic image of virtual disk. | Forensics Lead with IT Ops Lead | Day 0, 09:05 to 09:30 WAT. Planned, not yet collected. |
| **EV-04** | Microsoft 365 sign-in, unified audit and mailbox rule logs for the finance officer account (E02) | Export through compliance and admin portal, as CSV and native format, before any account changes where possible. | Security Analyst | Day 0, 08:50 to 09:05 WAT. Planned, not yet collected. |
| **EV-05** | Proxy and firewall logs for the 1.2 GB transfer (E04) | Export unfiltered log segment covering Day -1 16:00 to Day 0 09:00 for the host and destination. | Security Analyst | Day 0, 09:00 to 09:15 WAT. Planned, not yet collected. |

| | | | | |
|---|---|---|---|---|
| **EV-06** | BAK01 backup catalog, job and credential logs (E03, E05) | Read-only export of configuration and logs from the isolated console; photograph retention settings. | IT Ops Lead (witnessed by Forensics Lead) | Day 0, 09:10 to 09:30 WAT. Planned, not yet collected. |
| **EV-07** | Original E01 email with full headers, and mail trace | Export as .eml from the mailbox and message trace for all recipients; do not open the attachment outside a sandbox. | Security Analyst | Day 0, 09:20 to 09:40 WAT. Planned, not yet collected. |
| **EV-08** | Ransom note and sample encrypted files (E06) | Copy note and about 10 sample files from FS01 snapshot to evidence drive; photograph on-screen note. | Forensics Lead | Day 0, 09:15 to 09:25 WAT. Planned, not yet collected. |

| ID | Integrity check | Secure storage | Custody transfers (planned) |
|---|---|---|---|
| **EV-01** | SHA-256 of image to be calculated at acquisition and re-verified by a second person; value not yet recorded. | Encrypted evidence drive A in locked cabinet; sealed bag, label with ID. | Collector, then Evidence Custodian (Day 0, about 09:30), then DFIR provider (once engaged). Each step signed on custody form. |
| **EV-02** | SHA-256 of the image and the source disk (where supported) to be calculated and recorded; working copy only for analysis. | Encrypted drive B; original sealed; second copy to off-site encrypted store after counsel confirms. | Collector to Custodian; Custodian to DFIR; return on case closure. |
| **EV-03** | Hash on snapshot export; compare after copy; log hashes before and after transfer. | Encrypted drive A; never stored on FS01 or the corporate network. | IT Ops Lead to Forensics Lead, then Custodian; signed at each hand-over. |
| **EV-04** | Hash of each export file; export timestamp and exporter identity noted in the portal audit. | Encrypted drive A (copy); original export kept in restricted case folder outside corporate shares. | Security Analyst to Custodian. |
| **EV-05** | Hash of exported log files; compare against a second export if available. | Encrypted drive A. | Security Analyst to Custodian, then DFIR. |
| **EV-06** | Hash of exports; screenshot of settings with time stamp; second person witnesses. | Encrypted drive B; offline media kept in a separate locked safe. | IT Ops Lead to Forensics Lead to Custodian. |
| **EV-07** | Hash of .eml; verify headers unchanged; sandbox detonation results stored separately. | Encrypted drive A; malware samples in a labelled quarantine folder. | Security Analyst to Custodian, then DFIR. |
| **EV-08** | Hash of each copied file and of the note photo. | Encrypted drive A. | Forensics Lead to Custodian. |

**Access restrictions.** Access is limited to the Forensics Lead, the Evidence Custodian, the IR Lead and the external DFIR team. Originals stay sealed; analysis uses verified working copies. Two people are present whenever a sealed item is opened, and every access is logged (who, when, why). Evidence is stored on encrypted drives in a locked cabinet in a room with controlled entry, never on FS01, BAK01 or in corporate

email. Clocks on collection devices are checked against a trusted time source and the offset is recorded. Counsel is told early so that the investigation can be conducted in a way that protects privilege and preserves evidence for any later proceedings. Guidance used: RFC 3227 on order of volatility and NIST SP 800-86 on forensic techniques (Brezinski and Killalea, 2002; Kent et al., 2006).

## 3.3 Two difficult decisions

**Decision A: containing quickly while preserving useful evidence**

Evidence E06 shows encryption already visible on a workstation and a server, so waiting is not safe. My choice is network isolation first, memory capture second, shutdown last. Isolation takes seconds, stops encryption from reaching more shares and stops exfiltration, and leaves the machine's memory intact. Memory capture follows within minutes.

**Immediate isolation is necessary when** encryption is actively spreading to more systems or shares; data is still leaving the network; the attacker is live on a host; or backups are at risk. All four are plausible today (E03, E04, E06). **If a system cannot be network-isolated quickly,** I would suspend the virtual machine (which writes its memory state to disk) or, failing that, power it off, and accept the loss. **I will document any evidence loss** in an evidence-impact entry in the decision log: what was lost or altered, why, who decided, and the time between E06 and the action. I will treat the operational impact the same way: which services were down, from when, and which learners and staff were affected. This lets investigators and counsel judge how far to rely on the remaining evidence.

**Decision B: restoring examination access while backup safety is uncertain**

Management will want the portal open before 11:00. The options are:

- **Reopen the current portal.** Rejected. LMS01 is not verified, its content lives on an encrypted server (E07), and reconnecting risks reinfection and unreliable assessment records.
- **Restore from the latest network backup on BAK01.** Rejected for now. The repository was reached by svc_backup out of pattern (E03), and success messages prove nothing about contents (E05).
- **Build a clean, isolated examination environment from the validated Friday 17:00 disconnected backup.** Acceptable **only if every criterion below is met by 10:15**.
- **Postpone or run the exam offline.** The fallback if the gate fails. I expect this is the more likely outcome, and the gate exists so that the decision is made deliberately and not by default.

**Go criteria (all required):** the offline backup passes catalog and hash checks and a malware scan in a sandbox; exam content restores with no unexplained discrepancy and every exam file opens; the exam instance sits on a separate network segment with newly created credentials and EDR installed; it holds only exam content and the 100 candidates' fresh accounts, with no connection to compromised stores; svc_backup and the finance account remain disabled; rollback is ready; invigilators are briefed; and the Business Owner accepts the residual risk in writing with Principal approval. If any item fails, the exam is postponed, learners are told by 10:20, and fairness arrangements are recorded.

## 3.4 Eradication, entry point and credentials

- **Entry point.** The likely route is the payroll attachment (E01), still a hypothesis until EV-02 and EV-07 are analysed. Actions: remove the email from all mailboxes by purge; block the sender, domain and attachment type; disable macros from internet-sourced files; strengthen mail filtering; and verify from logs that no second route (for example exposed remote access) was used before declaring it closed.
- **Persistence.** Rebuild FIN-PC07 rather than clean it. For FS01, prefer a rebuild with data restored into it. Check and remove scheduled tasks, services, registry run keys, WMI subscriptions, new local and cloud accounts, mailbox rules and OAuth app consents. A second person verifies each item and an indicator hunt must come back empty.
- **Credentials.** After containment (resetting earlier lets the attacker re-capture them), reset passwords and revoke sessions and tokens for the finance officer, svc_backup (replaced with a least-privilege, vaulted account), all administrator accounts, any account that signed in on FIN-PC07 or FS01, and backup console credentials. Re-register MFA for affected users. Confirm from sign-in logs that no previous token is still accepted.

| Tier | Service | Recovery target (RTO) | Acceptable data loss (RPO) | Reason for order |
|---|---|---|---|---|
| 1 | Trusted identity and coordination channel (cleaned Microsoft 365 tenant, admin workstations) | Within 4 hours | No data restore needed; accounts re-secured | Everything else depends on safe identity and a trusted way to coordinate. |
| 2 | Examination environment (clean LMS instance with exam content only) | By 10:15 gate, otherwise within 24 hours of the rescheduled date | Content as at Friday 17:00; submissions re-taken, none lost | Only hard external deadline (A3); small, controllable scope. |
| 3 | LMS01 full service and learner-facing content on FS01 | Within 48 hours | Up to Friday 17:00 plus reconstruction from LMS logs and learner resubmissions | Restores teaching and assessment; reconciles weekend changes. |
| 4 | FS01 admissions and assessment records | Within 72 hours | Friday 17:00 backup (about 63.5 hours of changes at risk); gaps rebuilt from email, forms and staff records | Supports registry work; needs the most validation. |
| 5 | Finance systems (rebuilt FIN-PC07, finance shares) | Within 72 hours, interim manual process earlier | Friday 17:00 plus manual re-entry | Highest exfiltration concern, so restored last among critical systems. |
| 6 | Remaining endpoints, archives and non-critical services | Up to 7 days | As available | Lower impact; gives time to confirm no broader compromise. |

**On acceptable data loss.** The last disconnected backup is from Friday 17:00. Between then and E06 (Monday 08:30) is about 63.5 hours, so up to that much work could be lost on restored systems. The Business Owner must accept this explicitly. I would reduce the loss by reconstructing from LMS logs (once checked), email copies (once verified), paper or scanned records and learner resubmissions. For the future, I recommend a target of 24 hours or less for file data and 4 hours or less for the LMS database (Task 2, improvement 1).

**Selecting and validating the backup.** I choose the candidate that pre-dates every suspicious event: the Friday 17:00 offline set pre-dates E01 (Sunday 16:40) by about 47 hours. I then (1) verify the physical custody and catalog integrity; (2) scan the data in an isolated sandbox; (3) restore into a controlled, isolated VLAN, not production; (4) check integrity by comparing file counts and sizes, comparing hashes against the catalog, opening a sample of files and checking database consistency; and (5) hold monitoring in place before reconnecting anything. Network backups from BAK01 are considered only after separate validation and never for the exam.

## 3.6 Recovery acceptance criteria

| No. | Criterion and measure | Evidence | Signs off |
|---|---|---|---|
| 1 | **Clean source:** backup predates earliest suspicious activity (E01); catalog hashes match; sandbox malware scan returns no detections. | Validation report with scan output and hash comparison | Security Analyst and IT Ops Lead |
| 2 | **Data integrity:** no unexplained mismatch in file counts and sizes; 100% of exam files open; sampled FS01 files open; database consistency check passes. | Reconciliation sheet; test logs | IT Ops Lead; Forensics Lead reviews |
| 3 | **Hardened environment:** all credentials reset; MFA enforced for admins; EDR active on every restored server; patches applied; entry route closed. | Configuration checklist; EDR coverage report | IR Lead |
| 4 | **No indicators:** hunt across restored and neighbouring hosts returns zero matches, repeated after 24 hours. | Hunt queries and results | Security Analyst |
| 5 | **Function:** a test learner can log in, open materials and submit an assessment end to end; submissions are stored and readable. | Test script and results | Business Owner delegate |
| 6 | **Monitoring in place:** named analyst, alert thresholds set, no unresolved high-severity alert; watch continues for 14 days. | Monitoring plan; alert log | IR Lead |
| 7 | **Rollback ready:** tested way to isolate the service again within 15 minutes. | Rollback test record | IT Ops Lead |
| 8 | **Business approval:** residual risk and data loss accepted in writing; Principal informed; communications ready. | Signed approval record | Business Owner (accountable); Principal informed |

# Task 4: Communication and escalation

Stage: containment, eradication and recovery, running alongside the technical response. The rule I apply to every message is that it says what we know, what we do not, what we need from the reader and when the next update will come. It never states an unverified fact.

## 4.1 Communication matrix

| Stakeholder group | Trigger | Message owner | Channel (alternative if email unsafe) | Approver | Update frequency |
|---|---|---|---|---|---|
| **Principal and senior management** | Incident declared as Critical; any change in scope or severity; decisions needed | IR Lead | Phone call, then secure messaging group. Alternative: in-person briefing. | IR Lead (internal) | First update by 09:25; then hourly while Critical |
| **IT and security staff (CSIRT)** | Declaration; every containment or recovery step | IR Lead | Phone call tree and secure messaging group; whiteboard in the operations room | IR Lead | Continuous; formal handover each 4 hours and at shift change |
| **All staff (90)** | Any change to how people work; phishing warning; once scope is understood | Communications Lead | SMS or voice broadcast; notice board; verified email only after the tenant is declared safe | Principal and Legal Adviser | At 09:45, then twice daily |
| **Learners (1,800), with the 100 exam candidates addressed separately** | Service disruption; exam status; any confirmed personal data exposure | Communications Lead (with Business Owner for exam) | SMS; website notice hosted outside institute servers; social media post; campus notice. Alternative: phone tree through programme leaders. | Principal; Legal Adviser for any data statement | At 10:15, then at least every 4 hours and at each decision |
| **Service providers (M365 partner, backup vendor, DFIR provider)** | Need for support or logs; credential or tenant actions | IT Operations Lead | Supplier hotlines and named support contacts by phone, then ticket from a clean device | IR Lead | On engagement; then at agreed intervals (at least daily) |
| **Legal and privacy advisers (DPO and external counsel)** | Declaration; any indication of personal data exposure; extortion claim | IR Lead | Phone, then encrypted file transfer from a clean device | Principal (engagement) | Within 1 hour of declaration; then at each material finding |
| **Data protection regulator and other formal recipients** | Counsel determines notification is required (see 4.3) | Legal and Privacy Adviser | Official regulator channel as advised by counsel | Principal, after counsel advice | As set by counsel and the regulator |
| **Media and public** | Journalist enquiry; social media claim | Communications Lead (sole spokesperson) | Prepared holding statement; website | Principal and Legal Adviser | As needed; no ad hoc comments by staff |

**If corporate email is unsafe or unavailable (E08).** I treat email as untrusted for incident traffic until the Microsoft 365 checks in Task 3 are complete. Coordination uses phone calls, SMS and a secure messaging group created for the CSIRT, which carries no sensitive data (no file names of affected records, no credentials). Public notices go to a static page hosted away from institute servers, to SMS, and to the physical notice board. A printed out-of-band contact card (below) is kept by every CSIRT member.

| Role | Name (fictional) | Mobile (fictional) | Alternate |
|---|---|---|---|
| **Principal (Executive Sponsor)** | Dr. A. Eze | +234 800 555 0101 | Deputy Principal: +234 800 555 0102 |
| **IR Lead** | Incident Response Lead | +234 800 555 0103 | IT Operations Lead: +234 800 555 0104 |
| **Security Analyst** | T. Bello | +234 800 555 0105 | External DFIR hotline: +234 800 555 0106 |
| **Head of Academic Operations** | N. Okoro | +234 800 555 0107 | Registrar: +234 800 555 0108 |
| **Data Protection Officer / counsel** | C. Adeyemi | +234 800 555 0109 | External counsel: +234 800 555 0110 |
| **Communications Lead** | F. Ibrahim | +234 800 555 0111 | Student services: +234 800 555 0112 |

## 4.2 Executive briefing and learner notice

**Executive briefing to the Principal and senior management, issued by phone and read out, 09:15 WAT, Day 0.**

**Confirmed.** Ransomware has encrypted files on the finance workstation FIN-PC07 and the file server FS01 (E06). Learners can reach the portal login page but cannot open materials or submit work (E07). The incident contact list was held on FS01, so we are coordinating by phone (E08).

**Uncertain.** We do not yet know whether learner or finance data was stolen. FIN-PC07 sent 1.2 GB to unfamiliar cloud storage overnight (E04), but the contents are unknown. We also cannot yet confirm that our network backups are clean (E05).

**Done so far.** Affected systems are isolated, privileged accounts are disabled, and evidence capture has begun under strict custody controls.

**Decisions needed by 09:45.** (1) Approve continued isolation of FS01, LMS01 and BAK01. (2) Authorise external forensic support and legal counsel. (3) Agree that the 11:00 examination will be decided at a 10:15 go/no-go gate and will not run on unverified data.

**Next update:** 10:00 WAT, by phone.

**Learner notice, issued by SMS and website at about 09:30 WAT, Day 0 (the exam candidates receive the same text).**

**Subject: Important update: learning portal and 11:00 examination**

Dear learner,

We are dealing with a cyber incident affecting some of our systems. The learning portal may be unavailable, and you may be unable to open materials or submit work. We have taken affected systems offline to protect your information. We have not confirmed that any personal information has been accessed.

**If you are due to sit the 11:00 examination:** please do not assume it is cancelled. We will confirm by 10:15 whether it goes ahead or is rescheduled. If it is rescheduled, no learner will be penalised.

Please do not open attachments or links in unexpected messages claiming to be from the Institute, and never reply with your details. Report suspicious messages on 0800 555 0100 (fictional).

**Next update:** 10:15 WAT on the website notice board and by SMS.

## 4.3 Notification obligations and legal assessment

**Operational notices and formal breach notification are different things.** The executive briefing and learner notice above are operational: they keep people safe and informed. They neither admit nor deny a personal data breach and do not start or satisfy any legal duty. A formal notification is a legal act to a regulator or to affected individuals, made only after the Legal and Privacy Adviser has advised and the Principal has approved.

**How legal and privacy advisers will assess it.** I brief the Data Protection Officer and external counsel within one hour of declaration and give them the evidence log. They then work through these questions, recording each answer and its basis in the decision log:

- Is personal data involved (learner contact details, admission documents, assessment records, finance files)? Which categories, and roughly how many individuals?
- Is this a "personal data breach" in law? Encryption that makes data unavailable can itself qualify, even before theft is proven.
- Is there a likely risk, or high risk, to the rights and freedoms of the people concerned? This depends on the data type, the extortion threat and whether data could be published.
- When did the institute "become aware"? I propose to treat 08:30 on Day 0 (E06) as the conservative planning anchor, while counsel decides whether an earlier moment applies.
- Who must be told, and by when: the regulator, affected individuals, insurer, law enforcement, payment or exam partners, and any contract counterparties.

**Jurisdiction and deadline (assumption A1: Nigeria).** Under section 40 of the Nigeria Data Protection Act 2023, a data controller must notify the Nigeria Data Protection Commission within 72 hours of becoming aware of a breach that is likely to result in a risk to the rights and freedoms of individuals, and must communicate the breach to affected individuals immediately where it is likely to result in a high risk (Federal Republic of Nigeria, 2023; Mondaq, 2023). Using the conservative anchor of 08:30 on Day 0, my planning deadline for the regulator is **08:30 on Thursday (Day 3)**. This is a planning date, not legal advice: counsel must confirm the wording of the Act, the Commission's current process and any sector rules. If the institute were in another jurisdiction, I would not use this deadline.

## 4.4 Escalation rules

| Trigger | Escalate to | Time limit |
|---|---|---|
| Severity classified as Critical | Principal; DPO and counsel; DFIR provider | Principal in 15 minutes; others in 1 hour |
| Evidence or claim that personal data left the network (E04 confirmed, attacker proof) | Legal and Privacy Adviser, then Principal for notification decision | Immediately; written assessment within 4 hours |

| | | |
|---|---|---|
| Extortion threat, ransom demand or publication deadline | Principal and counsel; law enforcement through counsel. No contact with the attacker without Principal approval. | Immediately |
| Journalist or social media enquiry | Communications Lead only; approved holding statement | Response within 15 minutes of approval |
| Backup compromise confirmed or restore test failure | Principal and Business Owner (recovery plan and exam decision) | Within 30 minutes |
| Deadline at risk (examination or other fixed date) | Business Owner and Principal | At the next gate; never later than 1 hour before the deadline |
| IR Lead unreachable for 15 minutes | IT Operations Lead acts as deputy and informs the Principal | Automatic |

# Task 5: Tabletop exercise and improvement plan

Stage: post-incident activity and preparation. I designed a 60-minute discussion-based tabletop to test the plan in Tasks 2 to 4. Because Northbridge's exercise team is a single person for this assignment, I played every participant in turn. **Everything in sections 5.2 to 5.4 is a simulation. None of it describes a real event or real timings.**

## 5.1 Exercise design

**Objectives.** (1) Test whether the CSIRT can be activated without the FS01 contact list. (2) Test whether the examination decision is made on explicit safety criteria and not under pressure. (3) Test backup-failure handling. (4) Test whether holding statements and legal escalation work at speed. (5) Find gaps in roles, approvals and the decision log.

**Scenario clock.** Exercise minute 0 corresponds to 09:00 WAT on Day 0, so the 11:00 examination is still 2 hours away at the last inject (minute 45 is 09:45).

| Participant (played by me) | Exercise focus | Decision they must be ready to make |
|---|---|---|
| **Facilitator and controller** | Reads injects, keeps time, does not decide | None |
| **IR Lead (Incident Manager)** | Severity, direction, gate decisions | Containment priorities; exam gate; backup trust |
| **Security Analyst** | Indicators, M365 and credential actions | What to disable or revoke now |
| **Forensics Lead** | Evidence and custody | What to preserve; what evidence loss to accept |
| **IT Operations Lead** | Restore tests and rebuilds | What can be restored and how fast |
| **Business Owner (Head of Academic Operations)** | Exam and learner impact | Run, postpone or alter the exam |
| **Legal and Privacy Adviser** | Notification assessment | Whether and when formal notice is required |
| **Communications Lead** | Statements, learner and media messaging | Wording and timing |
| **Principal (Executive Sponsor)** | Approvals and public position | Approve statements, spend and postponement |
| **Scribe and observer** | Decision log and timing | Records times against success criteria |

| Exercise minute | Scenario clock | Activity |
|---|---|---|
| 0 to 5 | 09:00 | Briefing, ground rules and situation summary (Task 1 evidence E01 to E08). Roles confirmed. |
| 5 to 10 | 09:05 | Free play: initial containment and call-tree activation by phone. |
| 10 | 09:10 | **Inject 1:** management asks to reopen the portal before 11:00 even if the latest backup is unverified. |
| 20 | 09:20 | **Inject 2:** attacker claims to hold all 1,800 learner records and threatens publication in 12 hours; screenshot of unknown authenticity. |
| 28 | 09:28 | **Inject 3 (my own):** M365 audit shows a new inbox forwarding rule and an unknown app consent on the finance officer's mailbox, created at 01:20. |
| 35 | 09:35 | **Inject 4:** test restoration of the latest network backup fails with an unreadable snapshot error. |
| 45 | 09:45 | **Inject 5:** social media post says the exam is cancelled; a journalist asks whether learner information has been exposed. |
| 52 to 60 | 09:52 | Hot wash: score the success criteria, list gaps, agree actions. |

**Measurable success criteria.**

- **SC1.** All nine CSIRT roles are reached through the out-of-band call tree within 15 minutes of declaration.
- **SC2.** Every inject receives a logged decision (owner, rationale, communication) within 5 minutes.
- **SC3.** The examination decision applies the written go/no-go criteria, and no unverified data is placed in production.
- **SC4.** A holding statement is approved and issued within 15 minutes of the media inject, containing no unverified claim.
- **SC5.** Counsel is engaged and a breach assessment is opened within 30 minutes of the extortion claim, with the notification clock anchor recorded.
- **SC6.** An alternative recovery path is named within 10 minutes of the failed restoration.

## 5.2 Simulated walkthrough by role

### Inject 1, minute 10 (09:10): management asks to reopen the portal.

| Role played | Simulated response |
|---|---|
| **Principal** | Asks why 100 learners should be disrupted if the portal login page already loads (E07). Wants it open by 11:00. |
| **IR Lead** | Explains that the page loading does not mean the service is safe. The data sits on an encrypted FS01 and LMS01 is unverified. Declines to reopen on current systems; proposes the 10:15 gate and a clean exam build. |
| **Security Analyst** | Confirms reinfection and data-integrity risks; starts the sandbox scan of the Friday backup. |
| **IT Operations Lead** | Estimates that a clean exam instance is possible within the hour only if the Friday backup passes checks. Warns it is tight. |
| **Business Owner** | Agrees to the gate and starts drafting a postponement and fairness plan in parallel. |
| **Communications Lead** | Prepares two learner messages (go and no-go) for use at 10:15. |

### Inject 2, minute 20 (09:20): attacker claims all 1,800 records and threatens publication in 12 hours.

| Role played | Simulated response |
|---|---|
| **Principal** | Asks whether to pay or negotiate. Told not to contact the attacker without counsel, and agrees. |
| **Legal and Privacy Adviser** | Treats the claim as credible but unverified. Opens the breach assessment, records a conservative awareness anchor of 08:30 (E06), and brings the 72-hour planning date forward in the log. |
| **Forensics Lead** | Asks for the original screenshot file with metadata and logs it as a new evidence item (EV-09). Does not trust the image alone. |
| **Security Analyst** | Prioritises Q2 (what left the network): proxy detail for E04, file-access audit on FS01, any staging archives. |
| **IR Lead** | Keeps severity at Critical. Orders the 12-hour publication threat to be treated as a planning deadline: affected-data assessment must be available in 6 hours. |
| **Communications Lead** | Prepares a holding statement; no reference to the claim until counsel agrees wording. |

### Inject 3, minute 28 (09:28), my own: unknown forwarding rule and app consent on the finance mailbox.

| Role played | Simulated response |
|---|---|
| **Security Analyst** | Finds the rule forwards mail to an external address and the app consent grants mailbox read access. Deletes both after exporting them as evidence. |
| **IT Operations Lead** | Revokes all sessions and consent grants for finance users; forces password reset and MFA re-registration across the finance team. |

| | |
|---|---|
| **Forensics Lead** | Exports the rule and consent records before removal and notes the creation time of 01:20, five minutes after E02. |
| **IR Lead** | Declares corporate email untrusted for incident traffic, and widens scope to "possible mailbox compromise". Raises a Microsoft support case. |
| **Communications Lead** | Confirms all messaging remains on phone, SMS and the secure group. |

### Inject 4, minute 35 (09:35): restore of the latest network backup fails with an unreadable snapshot error.

| Role played | Simulated response |
|---|---|
| **IT Operations Lead** | Reports the failure and that it cannot be told whether it is corruption or tampering. Isolates the snapshot set unchanged. |
| **Forensics Lead** | Takes the repository logs as evidence; asks the backup vendor for support through a named contact. |
| **Security Analyst** | Notes that this fits the concern in E03 and E05 and raises the probability that BAK01 was tampered with. |
| **IR Lead** | Marks all BAK01 data untrusted. Names the Friday 17:00 offline backup as the only candidate and orders validation in the sandbox. |
| **Business Owner** | Accepts that the exam gate is now unlikely to be met by 10:15, and asks for the postponement notice to be ready. |
| **Principal** | Told that recovery estimates have moved; approves external DFIR spend. |

### Inject 5, minute 45 (09:45): social media post claims exam cancelled; journalist asks about exposure.

| Role played | Simulated response |
|---|---|
| **Communications Lead** | Drafts a holding statement and routes every enquiry through the Communications desk. Does not confirm cancellation or exposure. |
| **Legal and Privacy Adviser** | Reviews wording: "we are investigating; we have no confirmation that personal information has been accessed". Rejects any "no data was stolen" claim. |
| **Principal** | Approves the statement and names the Communications Lead as sole spokesperson. |
| **Business Owner** | Confirms the exam status will be settled at 10:15, and asks that learners be told not to rely on social media. |
| **IR Lead** | Keeps technical staff off social media; logs the post and enquiry for the review. |

## 5.3 Decision log (simulated)

| ID | Inject | Decision | Owner | Rationale | Communication | Effect on plan |
|---|---|---|---|---|---|---|
| **D1** | 1 (min 10) | Do not reopen the portal on current | IR Lead with Business Owner | E05 and E07 give no assurance of | Principal and Business Owner | Adds a clean-room exam workstream; |

| | | | | | | |
|---|---|---|---|---|---|---|
| | | or unverified systems. Set a 10:15 go/no-go gate and build a clean exam instance in parallel. | | integrity; reinfection and unreliable results are worse than a delay. | by phone; invigilators on standby | sets gate criteria as a formal plan item |
| **D2** | 2 (min 20) | Treat the claim as credible but unverified; no contact with the attacker; preserve the screenshot (EV-09); open breach assessment. | Principal (engagement) and Legal Adviser | Paying or replying could worsen risk and affect legal position; the claim could be bluff, but E04 prevents dismissal. | Counsel and Principal only; not public | Brings forward exfiltration analysis; draft notification prepared; planning deadline logged |
| **D3** | 3 (min 28) | Treat email as untrusted; remove the forwarding rule and consent after export; reset finance team credentials. | IT Operations Lead and Security Analyst | Active mailbox access explains E08 and means incident email would be seen by the attacker. | CSIRT by phone; finance staff by call | Widens scope to Microsoft 365; keeps all coordination out-of-band |
| **D4** | 4 (min 35) | Mark all BAK01 snapshots untrusted; use only the validated Friday offline backup; validate it in a sandbox first. | IR Lead | Failure and E03 together mean the repository cannot be relied on. | Business Owner and Principal | Recovery time estimates extended; exam gate probability falls |
| **D5** | 5 (min 45) | Issue a holding statement: no confirmation of cancellation or exposure; exam status by 10:15. | Principal (approval); Communications Lead (issue) | Counters the rumour without making unverified claims. | Website, SMS, social media; media enquiry log | Adds a 10:15 learner update to the schedule; locks one spokesperson |
| **D6** | 5 (min 50) | If the gate criteria are not all met at 10:15, the exam is postponed automatically; prepare the postponement notice now. | Business Owner with Principal approval | Avoids re-negotiating safety under time pressure. | Draft notice ready for Communications Lead | Postponement and fairness arrangements become the default path |

## 5.4 Evaluation against success criteria (simulated results)

These results are simulated. I scored the exercise honestly against the stated targets, including where I would expect the plan to struggle.

| No. | Criterion and target | Simulated result | Status |
|---|---|---|---|
| **SC1** | All nine roles reached in 15 minutes or less. | All reached, but it took about 21 minutes because numbers had to be gathered from personal phones. | Partially met |

| | | | |
|---|---|---|---|
| **SC2** | Every inject logged within 5 minutes. | Six decisions logged; five within 5 minutes. D3 took about 7 minutes because no template existed for evidence-loss entries. | Partially met |
| **SC3** | Exam decision by written criteria; no unverified data in production. | Criteria applied at inject 1 and D6; nothing unverified was placed in production. | Met |
| **SC4** | Holding statement approved and issued within 15 minutes. | Drafted in 8 minutes but approval took about 18 minutes in total because the approval order (Principal or Legal first) was unclear. | Not met |
| **SC5** | Counsel engaged and assessment opened within 30 minutes of the extortion claim. | Counsel contacted in about 25 minutes; anchor and planning date recorded. | Met |
| **SC6** | Alternative recovery path within 10 minutes of the failed restore. | Friday offline backup named within about 6 minutes. | Met |

Overall: three of six criteria met, two partially, one not met. The plan's technical decisions held up; its weaknesses are administrative: contact information, templates and the approval path. These are cheap to fix, which is what exercise is for.

## 5.5 Improvement plan

| # | Improvement | Priority | Owner | Target completion | Measurable evidence of completion |
|---|---|---|---|---|---|
| 1 | Create and distribute the out-of-band contact list (printed cards, phone copies, externally hosted copy). | High | IR Lead | 7 days | Nine role-holders confirm receipt; drill reaches all within 15 minutes. |
| 2 | Pre-approve holding statements and set one approval order (Legal Adviser reviews, Principal approves, Communications Lead issues). | High | Communications Lead | 14 days | Signed template library; next exercise issues a statement within 10 minutes. |
| 3 | Test restores for FS01 and LMS01 and move to immutable or offline copies. | Critical | IT Operations Lead | Test in 14 days; immutability in 60 days | Signed restore report with measured times; immutability configuration evidence. |
| 4 | Write an examination contingency procedure, including a clean exam build runbook and offline or rescheduled options. | High | Business Owner | 30 days | Approved procedure; exam content restored to a sandbox in under 2 hours in a test. |
| 5 | Add Microsoft 365 alerts for new inbox rules, app consents | High | Security Analyst | 21 days | Alerts live; a safe test triggers each within 5 minutes. |

| | | | | | |
|---|---|---|---|---|---|
| | and unusual admin sign-ins; tighten conditional access. | | | | |
| 6 | Add decision-log and evidence-impact templates and train two scribes. | Medium | IR Lead | 14 days | Templates in use; next exercise logs 100% of decisions within 5 minutes. |

**Post-incident review deadline and closure.** For the exercise, I hold the review within 5 working days. For a real incident, the post-incident review is held within 14 days of declaration (no later than Monday, Day 14) and a written report goes to the Principal within 5 working days after that. The IR Lead chairs the review and maintains the action tracker. Each action is closed by the IR Lead only when the owner supplies the measurable evidence listed above. The Principal, as Executive Sponsor, formally closes the whole action plan and signs off any action that is overdue by more than 14 days, accepting the risk or setting a new date. Overdue Critical or High actions are escalated to the Principal without waiting for the next review.

# Task 6: Case study analysis and critical reflection

**Strengths.** First, recovery was prioritised by service criticality rather than restoring everything at once, which matches an impact-led approach (NIST, 2025). Second, care continued through manual downtime procedures, so continuity did not depend on IT recovery. Third, recovery was staged, separating urgent service return from slower, evidence-led full restoration.

**Limitations.** It remains unresolved whether patient data was taken; absence of evidence is not evidence of absence, particularly where logging is incomplete. Speed of restoration also creates a reinfection risk if the root cause and persistence are not yet understood.

**Changes I would transfer.** (1) Explicit tiered recovery targets with a manual fallback. Northbridge needs this for the 100-learner examination: a paper-based or rescheduled option prepared by the Business Owner before the technical recovery completes. (2) A rule that nobody states "no data was stolen" until defined evidence exists. This is directly relevant to E04 and the journalist inject, where a premature denial could later be disproved.

**72 hours versus seven days.** Seventy-two hours restores a minimum viable service: rebuilt, clean systems, reduced functionality and limited users, with workarounds around them. Full restoration over seven days also covers re-imaging remaining endpoints, validating data, reconnecting integrations, clearing backlogs, hardening and monitoring. Treating the two as one target would push teams to rush validation.

**Evidence before claiming no data was stolen.** I would want complete logs covering the whole intrusion, from first access (E01) to containment: proxy, firewall, DNS and flow records showing every outbound transfer; endpoint telemetry from all hosts; file-access audit trails; forensic review of staging archives; and no attacker proof or leak-site listing. Where logs or EDR are missing, as on Northbridge's servers, the honest statement is "we have found no evidence", with scope and confidence given.

**Decision I would revise.** After the tabletop, I would change the 10:15 gate: validating a backup in under an hour is unrealistic, and the failed restore showed how fast rumour fills a gap. I would decide by 09:45 that the exam is postponed unless every criterion is already met.

# Reference


Brezinski, D. and Killalea, T. (2002) RFC 3227: Guidelines for evidence collection and archiving. Internet Engineering Task Force. Available at: https://www.rfc-editor.org/info/rfc3227

CISA (n.d.) #StopRansomware Guide. Cybersecurity and Infrastructure Security Agency. Available at: https://www.cisa.gov/resources-tools/resources/stopransomware-guide

Federal Republic of Nigeria (2023) Nigeria Data Protection Act, 2023, section 40 (personal data breach). Counsel should confirm the official text through the Nigeria Data Protection Commission.

Kent, K., Chevalier, S., Grance, T. and Dang, H. (2006) NIST Special Publication 800-86: Guide to integrating forensic techniques into incident response. National Institute of Standards and Technology. Available at: https://csrc.nist.gov/pubs/sp/800/86/final

Mondaq (2023) Data breaches: compliance obligations under the Nigerian Data Protection Act 2023. 29 September. Available at: https://mondaq.com/nigeria/data-protection/1371660/data-breaches-compliance-obligations-under-the-nigerian-data-protection-act-2023

NIST (2025) Special Publication 800-61 Revision 3: Incident response recommendations and considerations for cybersecurity risk management. National Institute of Standards and Technology. Available at: https://csrc.nist.gov/pubs/sp/800/61/r3/final

NIST (n.d.) Incident Response project: framework and life cycle overview. National Institute of Standards and Technology. Available at: https://csrc.nist.gov/projects/incident-respons


## Authorship and AI assistance declaration

This assignment is my own analysis and I am prepared to explain any decision in it if the instructor asks. I used an AI writing assistant to help structure and draft parts of the text, and I have reviewed, edited and taken responsibility for all of the content, in line with the ICDFA course policy. All names, numbers and organisations in the scenario are fictional.